

الجمهورية الجزائرية الديمقراطية الشعبية

ⵜⴰⴷⵓⴷⴰⵢⵜ ⵜⴰⵎⴻⵔⴰⵏⵜ ⵜⴰⵖⴻⵔⴰⵢⵜ ⵜⴰⵣⴰⵢⴻⵔⴰⵢⵜ

République Algérienne Démocratique et Populaire

وزارة التعليم العالي والبحث العلمي

ⵎⴰⵎⴻⵏⵜ ⵜⴰⵎⴻⵔⴰⵏⵜ ⵜⴰⵣⴰⵢⴻⵔⴰⵢⵜ ⵜⴰⵖⴻⵔⴰⵢⵜ

Ministère de l'Enseignement Supérieur et de la Recherche Scientifique



ECOLE NATIONALE  
SUPÉRIEURE  
D'INFORMATIQUE

المدرسة الوطنية العليا للإعلام الآلي  
ⵎⴰⵎⴻⵏⵜ ⵜⴰⵎⴻⵔⴰⵏⵜ ⵜⴰⵣⴰⵢⴻⵔⴰⵢⵜ ⵜⴰⵖⴻⵔⴰⵢⵜ  
École nationale Supérieure d'Informatique

SSR, SIQ2

---

## LAB6B: ARP SPOOFING

---

Done by:

Benziada Fares Abderraouf

Grine Abderrahmane

May 2026.

## ARP Spoofing:

ARP is used to map IP addresses to MAC addresses inside a local network. Since ARP does not verify the authenticity of replies, attackers can send forged ARP responses to poison the ARP cache of a victim machine.

In an ARP spoofing attack, the attacker pretends to be another machine on the network, usually the gateway or a server. As a result, the victim sends traffic to the attacker instead of the real destination. This allows the attacker to sniff, modify, or redirect traffic.

The attack was launched from the Parrot Security machine using the arpspoof command:

[illegible]

This command continuously sent forged ARP replies to the victim machine, making the attacker appear as the legitimate server.

These are the result of spoofing, the images below represent the victim ARP cache before and after spoofing, we can observe clearly that the MAC address of the server (10.10.0.128) has changed to the attacker one (10.10.0.130).

```
C:\Users\eden.MYLAB>arp -a

Interface : 10.10.0.129 --- 0x10
Adresse Internet    Adresse physique    Type
10.10.0.1           00-50-56-c0-00-02  dynamique
10.10.0.128         00-0c-29-05-75-9d  dynamique
10.10.0.254         00-50-56-e3-a7-2a  dynamique
10.10.0.255         ff-ff-ff-ff-ff-ff  statique
224.0.0.22          01-00-5e-00-00-16  statique
224.0.0.251         01-00-5e-00-00-fb  statique
224.0.0.252         01-00-5e-00-00-fc  statique
239.255.255.250     01-00-5e-7f-ff-fa  statique
255.255.255.255     ff-ff-ff-ff-ff-ff  statique

Interface : 10.10.0.129 --- 0x10
Adresse Internet    Adresse physique    Type
10.10.0.1           00-50-56-c0-00-02  dynamique
10.10.0.128         00-0c-29-05-75-9d  dynamique
10.10.0.130         00-0c-29-05-75-9d  dynamique
10.10.0.254         00-50-56-e3-a7-2a  dynamique
10.10.0.255         ff-ff-ff-ff-ff-ff  statique
224.0.0.22          01-00-5e-00-00-16  statique
224.0.0.251         01-00-5e-00-00-fb  statique
224.0.0.252         01-00-5e-00-00-fc  statique
239.255.255.250     01-00-5e-7f-ff-fa  statique
255.255.255.255     ff-ff-ff-ff-ff-ff  statique
```

## Redirecting Traffic to the Attacker:

After poisoning the victim's ARP cache, the attacker machine needed to accept traffic intended for the legitimate server.

To achieve this, a virtual interface was configured on the attacker machine using:

```
sudo ifconfig ens33:0 10.10.0.128
```

This assigned the spoofed IP address of the legitimate server to the attacker machine. As a result, packets sent by the victim to the legitimate server were redirected to the attacker instead.

## Fake HTTPS Server:

Next, a fake HTTPS server was configured on the attacker machine. A different webpage was created to clearly distinguish it from the legitimate server.

The fake webpage displayed the message:

You have been hacked!

When the victim accessed <https://www.esi.dz>, the attacker server responded instead of the legitimate server.



## HTTPS and Certificate Security:

Initially, the HTTPS server used a self-signed certificate. Since self-signed certificates are not validated by a trusted Certificate Authority (CA), the client could not properly verify the identity of the server.

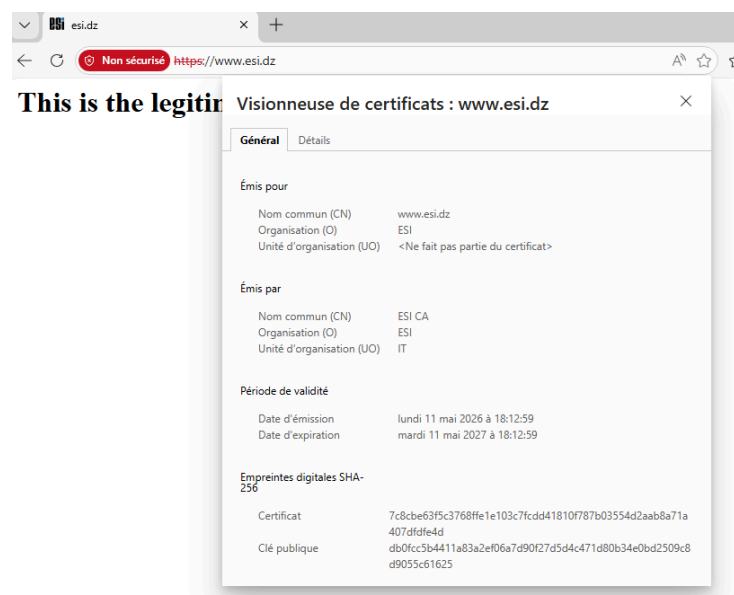
Because of this, the attacker could impersonate the legitimate server and the browser only displayed a warning message. If the user ignored the warning and accepted the certificate, the attack succeeded.

## Countermeasures:

To prevent the attack, CA-signed certificates were used instead of self-signed certificates. A trusted Certificate Authority validates that the certificate actually belongs to the legitimate domain owner.

When the victim connected to the legitimate server using a trusted certificate, the browser automatically verified the certificate.

This image represented the victim access after stopping the spoofing operation and clearing the cache (arp -d):



When we attempted to spoof the server again, the browser detected that the certificate was invalid and warned the user.

## **Defenses Against ARP Spoofing:**

ARP spoofing can be prevented using several security methods. CA-signed TLS certificates (as we saw in the lab) help protect users because browsers reject fake servers that use untrusted certificates.

We can use static ARP entries that improve security by manually fixing IP-to-MAC address mappings, which prevents attackers from changing them.

In addition, tools such as **arpwatch** can monitor networks and detect suspicious IP-to-MAC address changes, helping administrators identify possible attacks quickly.